Lab 12 — Manage Access with Azure RBAC

In this lab you explore Azure role-based access control (RBAC) on the `rg-az900-labs` resource group: you inspect built-in roles, assign the **Reader** role to the Lab 11 user `az900.learner`, prove that authorization blocks that user from creating resources, and then remove the assignment. This maps to the AZ-900 skill area "Describe Azure management and governance" (RBAC, scope and least privilege) and reinforces the difference between authentication (Microsoft Entra ID) and authorization (RBAC).

Run on https://portal.azure.com — sign in with your Azure free account (https://azure.microsoft.com/free).

Step 1 — Open Access control (IAM) on the resource group

1. In the portal search bar, type **Resource groups** and open it.
2. Click **rg-az900-labs** (if it does not exist, click **+ Create**, name it `rg-az900-labs`, region **Southeast Asia**, then open it).
3. In the left menu, click **Access control (IAM)**.

Every subscription, resource group and resource has this blade — RBAC works at all of these scopes.

Step 2 — View existing role assignments and scope inheritance

1. On the **Access control (IAM)** blade, click the **Role assignments** tab.
2. Find your own account in the list. Note the **Role** column shows **Owner** and the **Scope** column shows **Subscription (Inherited)**.

Role assignments flow downward: management group > subscription > resource group > resource. You never assigned Owner on this resource group directly — you inherited it from the subscription.

Step 3 — Compare Reader, Contributor and Owner role definitions

1. Click the **Roles** tab.
2. In the search box type **Reader**, then click **View** (under the **Details** column) on the **Reader** row.
3. On the **Permissions** tab note the single action: `*/read`.
4. Click the **JSON** tab to see the raw role definition. Close the pane.
5. Repeat for **Contributor** — actions `*` but with **NotActions** blocking `Microsoft.Authorization/*/Write` (cannot grant access to others).
6. Repeat for **Owner** — actions `*` with no RBAC restrictions.

Role	Can view	Can create/delete	Can grant access
Reader	Yes	No	No
Contributor	Yes	Yes	No
Owner	Yes	Yes	Yes

Step 4 — Assign the Reader role to az900.learner

1. Back on **Access control (IAM)**, click **+ Add** > **Add role assignment**.
2. On the **Role** tab, under **Job function roles**, select **Reader** and click **Next**.
3. On the **Members** tab:

- **Assign access to**: `User, group, or service principal`
- Click **+ Select members**, search for `az900.learner`, select the user, click **Select**.

1. Click **Review + assign** twice.

You have granted least-privilege access: the learner can see everything in this resource group but change nothing.

Step 5 — Test the assignment as az900.learner

1. Open a **private/incognito** browser window and go to https://portal.azure.com.
2. Sign in as `az900.learner@<yourtenant>.onmicrosoft.com` (password from Lab 11; change it if prompted).
3. Search for **Resource groups** — the user can now see **rg-az900-labs** and open the resources inside it (e.g. the Lab 9 storage account).

Signing in successfully is **authentication** (Entra ID proved who the user is); seeing the resource group is **authorization** (RBAC decided what they may do).

Step 6 — Prove that Reader blocks create and delete

1. Still signed in as `az900.learner`, open **rg-az900-labs** and click **+ Create**.
2. Search for **Storage account**, click **Create**, pick any name and click **Review + create** > **Create**.
3. The deployment fails with an authorization error similar to:

- `The client 'az900.learner@...' with object id '...' does not have authorization to perform action 'Microsoft.Storage/storageAccounts/write' over scope '/subscriptions/.../resourceGroups/rg-az900-labs' ...`

1. Also note that on any existing resource the **Delete** button is greyed out or fails the same way.
2. Sign out and close the private window.

Read the error carefully — it names the exact action and scope that was denied. This is RBAC enforcing least privilege.

Step 7 — Use Check access to query effective permissions

1. Back in your own (Owner) session, open **rg-az900-labs** > **Access control (IAM)** > **Check access** tab.
2. Click **Check access**, search for `az900.learner`, and select the user.
3. The pane lists the user's current assignments at this scope: **Reader**.

Check access is the quickest way to answer "what can this person actually do here?" without reading every assignment.

Step 8 — (Optional) List role assignments with the Azure CLI

Open Cloud Shell (the `>_` icon in the portal top bar, choose **Bash**) and run:

```
az role assignment list --resource-group rg-az900-labs -o table
```

`--resource-group` scopes the query and `-o table` gives readable columns; you should see the `az900.learner` Reader assignment (inherited subscription-level assignments are not shown unless you add `--include-inherited`).

Step 9 — Remove the role assignment

1. Go to **rg-az900-labs** > **Access control (IAM)** > **Role assignments** tab.
2. Tick the checkbox next to the **Reader** assignment for **az900.learner**.
3. Click **Remove** (or **Delete**), then confirm.

Removing an assignment revokes access immediately — the user keeps their Entra ID account (authentication) but loses authorization at this scope.

Clean up

1. Confirm the Reader assignment for `az900.learner` on `rg-az900-labs` is removed (Step 9).
2. No resources were created in this lab, so nothing else to delete. Keep `rg-az900-labs`, the Lab 11 user and group — later labs still use them.

What you learned

- RBAC assignments combine a **security principal + role definition + scope**, and assignments inherit down from management group > subscription > resource group > resource.

- **Reader**, **Contributor** and **Owner** are the core built-in roles; only Owner can manage access for others.
- **Authentication** (Microsoft Entra ID verifies identity) is separate from **authorization** (RBAC decides permitted actions).
- Assigning the least-privileged role needed (least privilege) limits the impact of mistakes and compromised accounts.
- **Check access** and `az role assignment list` let you audit who can do what at a given scope.

Files in this lab folder

File	What it is
`check-rbac.sh`	Lists your role assignments, what inherits from the subscription, and what `Reader` permits.

The scripts are optional conveniences — the lab steps above teach the same thing command by command. Upload a script to Cloud Shell (**Manage files > Upload**), or clone this repo there, then run it with `bash <script-name>`.